

[자기주도동아리]

자기주도동아리 웹해킹, Team1 - 취약점 Report -



성명	박은찬, 박수인, 현세은
담당멘토	유재욱 멘토님

목차

개요

- 수행방법
- 사용한 도구
- 수행기간
- 수행인원

취약점 분석

- 총평
- 취약점A
 - ＞ 개요
 - ＞ 취약한 endpoint
 - ＞ 취약점 상세설명
 - ＞ 조치방안
- 취약점B

결론

개요

본 보고서는 가천대학교 자기주도동아리 사업중 웹해킹 분야를 자기주도적으로 분석하여 역량을 기르기위한 과업으로 박은찬, 박수인, 현세은 3인이 웹해킹을 정리하여 기록한 보고서다.

개요

수행방법

웹해킹 하는 다른 3인 팀인 팀2의 사이트: <http://gachon.arang.kr:3002/> 를 목표로 하여 웹해킹을 실습하였으며 SQL Injection, XSS, File Directory로 각자 분야를 나누어 분석하였다.

사용한 도구

Chrome을 사용하여 웹페이지에 접속하여 수동으로 SQL injection, XSS, File Directory 취약점을 하였으며 추후 sqlmap, Burp Suite등의 도구를 사업이후 공부할 목표를 가졌다.

수행기간

총 2026년 5월 11일 ~ 2026년 5월 22일의 기간동안 수행하였습니다.

수행인원

박은찬, 박수인, 현세은 3인

취약점 분석

총평

박은찬: 일정이 겹쳐서 힘들었지만 성장한 느낌입니다.

박수인: 지금까지 배운 개념을 실제로 해서 되는걸 보고 뿌듯했습니다.

현세은: 시간이 많이 부족하여 많은 걸 하진 못하여서 다음에는 더 많은 걸 하고 싶습니다.

취약점A Web Application(웹) 2. SQL 인젝션 (SQL Injection)

개요

애플리케이션 내 입력값이 SQL 쿼리에 삽입되어 비인가된 데이터베이스 접근과 조작 가능 여부 점검
SQL 인젝션: 사용자의 입력값으로 웹 사이트 SQL 쿼리가 완성되는 약점을 이용하여, 입력값을 변조해 비정상적인 SQL 쿼리를 조합하거나 실행하는 공격. 이는 개발자가 의도하지 않은 SQL문을 실행하게 하여 데이터베이스를 비정상적으로 조작하고, 민감한 데이터를 조회, 수정, 삭제할 수 있는 공격

취약한 endpoint

<http://gachon.arang.kr:3002/auth/login>, POST

쿼리 id admin' OR 1=1 --'
pw 1

취약점 상세설명

취약 : 임의로 작성된 SQL 쿼리 입력에 대한 검증이 이루어지지 않아 비정상적인 쿼리가 실행되는 경우

SELECT * FROM users WHERE username = 'admin' OR 1=1 -- ' AND password = '...'

↑ 항상 참 ↑ 주석 처리된 table 등 안맞을 수는 있지만 위에처럼 뒤에 조건이 — 주석으로 무시되어서 admin으로 로그인 가능한 취약점

조치방안

소스코드 내 SQL 쿼리를 입력값으로 받는 함수나 코드를 사용할 경우, 임의의 SQL 쿼리 입력에 대한 검증 로직을 구현하여 서버에 검증되지 않는 SQL 쿼리 요청 시 에러 페이지가 아닌 정상 페이지가 반환되도록 필터링 처리하고 웹방화벽에 SQL 인젝션 관련 룰셋을 적용하여 SQL 인젝션 공격을 차단함

1. SQL 쿼리 내 사용되는 문자열의 유효성을 검증하는 로직 구현
2. 아래와 같은 특수문자에 대하여 사용자 입력값으로 지정 금지

문자	상세 설명
.	문자 데이터 구분 기호
:	쿼리 구분 기호
--, #	해당 라인 주석 구분 기호
/* */	/* 와 */ 사이 구문 주석

3. Prepared Statements를 사용하여 사용자 입력과 SQL 쿼리를 분리하여 처리
4. 시스템에서 제공하는 에러 메시지 및 DBMS에서 제공하는 에러코드가 노출되지 않도록 예외처리
5. 웹 방화벽(WAF)에 대하여 SQL Injection 관련 룰셋 추가

총평

수고하였습니다.